

Framework Selection Memo

GRC Practicum - Project 4 | NOVAtech Inc. (simulated scenario)

Note: NOVAtech Inc. is a fictional company; this memo is simulated for demonstration. The strategic reasoning reflects real-world framework selection considerations for a mid-market Canadian B2B SaaS.

EXECUTIVE SUMMARY

NOVAtech should pursue SOC 2 Type II first, use CIS Controls v8 (Implementation Group 2) as the internal build roadmap, and target ISO/IEC 27001:2022 certification as a 12 to 18 month follow-on. Canadian privacy compliance (PIPEDA, with Quebec Law 25 awareness) runs in parallel as a legal requirement regardless of framework selection. This sequence unblocks enterprise revenue fastest, provides engineering with prescriptive to-dos, and positions NOVAtech for international expansion without duplicating evidence work.

BUSINESS CONTEXT

NOVAtech is a 200-person Canadian B2B SaaS company hosting customer data in AWS ca-central-1, with a remote-first workforce. Growth strategy is enterprise expansion in North America first, then international deals in years 2 and 3. Current asset inventory (Project 4A) identifies 22 in-scope assets, of which 9 are Critical, 8 are High, and the highest-classification data handled is Restricted (payment tokens, employee SIN and banking) and Confidential PII.

FRAMEWORK COMPARISON

Dimension	SOC 2 (Type II)	ISO/IEC 27001:2022	CIS Controls v8
What it is	AICPA attestation report issued by a CPA firm	International certifiable ISMS standard	Prioritized safeguard checklist
Who cares most	Enterprise procurement in North America	International customers, regulated industries	Practitioners implementing security
Certifiable?	No (attestation only)	Yes, 3-year cert cycle	No
Cost & effort	Moderate (audit fees, evidence prep)	Higher (management system + audit)	Lowest (framework free; implementation only)
Time to first output	6-12 months to Type II	12-18 months typical	Immediate use as roadmap
Unblocks	Enterprise revenue in NA	International deals, regulated buyers	Nothing directly (internal quality)

Note: These frameworks are complementary, not competing. Roughly 70 percent of controls overlap; the strategic question is sequencing, not selection.

RECOMMENDATION AND RATIONALE

Sequence: SOC 2 Type II first

- **Commercial pressure:** Enterprise procurement in North America treats SOC 2 as a hard gate. Prospects request SOC 2 reports in vendor security questionnaires, and lacking one loses deals late in the cycle. SOC 2 unblocks revenue directly.
- **Achievable in 6 to 12 months:** Type I at month 6, then a 6-month observation window, then Type II delivered. Practitioners already operate the underlying controls (monitoring, access, incident response).
- **Trust Services Criteria alignment:** Security is mandatory; Availability and Confidentiality are logical additions for a SaaS platform. Privacy criterion pairs with PIPEDA program work.

Roadmap: CIS Controls v8 IG2

- **Prescriptive:** CIS says exactly what to implement in what order (Controls 1 and 2 for asset inventories, 3 for data protection, 4 for secure configuration, 5 and 6 for access management). Engineering can execute against it without translation.
- **Mapping shortcut:** CIS publishes crosswalks to SOC 2 TSC and ISO 27001 Annex A. Every CIS control implemented is evidence for multiple frameworks simultaneously.

- **IG2 (not IG1 or IG3):** IG1 is minimum hygiene, insufficient for a SaaS handling PII. IG3 is nation-state-adversary posture, over-scoped. IG2 is the fit for a 200-person company with regulated data.

Follow-on: ISO 27001:2022 certification (months 12 to 18)

- **International credibility:** Once expansion into European or Asia-Pacific deals begins, ISO 27001 is the credential enterprise buyers recognize. SOC 2 alone is North American.
- **Adds the management-system layer:** ISO 27001's Clauses 4 to 10 (context, leadership, planning, support, operation, evaluation, improvement) build the governance discipline that a growing organization needs. SOC 2's Trust Services Criteria are control-focused; ISO's clauses are program-focused.
- **Cost efficiency:** With SOC 2 evidence flows already in place, ISO gap-to-cert work focuses on management-system artifacts (ISMS scope, SoA, internal audit program, management review). Estimated 40 percent less effort than starting cold.

Parallel: PIPEDA compliance (all phases)

PIPEDA is a legal obligation, not a strategic choice. The privacy program (data map, breach response, RROSH assessment capability) supports both SOC 2 Privacy criterion and ISO 27001 A.5.34 (privacy and PII protection). Quebec Law 25 awareness is required if any customer or employee data touches Quebec; PayCo's Montreal data residency (A-13 in inventory) makes this near-certain. Watch for Canadian federal Bill C-27 progress and adjust program scope accordingly.

WHAT NOT TO DO

- **ISO 27001 first:** longer time to first credential (12 to 18 months vs 6 for SOC 2 Type I), and less commercially useful in a NA-first growth phase. Waste of time-to-revenue.
- **Pursue all three simultaneously:** fragmented attention across three programs, three sets of evidence conventions, and three audit cycles. Sequence, do not stack.
- **Skip CIS Controls:** without a prescriptive roadmap, teams debate what to implement instead of implementing. CIS is the fastest way to convert framework selection into engineering tickets.
- **Treat NIST CSF as the primary framework:** NIST CSF is a useful risk-communication and program-organization tool but is not certifiable and is not what enterprise procurement demands. Use it for internal maturity assessment, not as the target.

ESTIMATED TIMELINE AND MILESTONES

- Months 0 to 3: CIS Controls v8 IG2 gap assessment; asset inventory and data classification (delivered); ISMS scope statement drafted
- Months 3 to 6: Critical CIS controls implemented (asset mgmt, access, secure config); SOC 2 auditor selected; Type I readiness
- Month 6: SOC 2 Type I report issued (design of controls)
- Months 6 to 12: 6-month Type II observation window; PIPEDA program formalized; evidence collection discipline built
- Month 12: SOC 2 Type II report issued
- Months 12 to 18: ISO 27001 gap assessment; SoA drafted; internal audit program stood up; Stage 1 external audit
- Month 18: ISO 27001 Stage 2 audit; certification

THE STRUCTURE - REUSABLE SKELETON

What job each section of a framework selection memo does. Apply this same anatomy to any strategic decision paper.

- **Executive summary first:** the recommendation and one-sentence why. If leadership reads only this, they know what they are approving.
- **Business context:** frameworks are means to business ends. Anchor selection in growth strategy, buyer geography, data sensitivity, and workforce shape, not framework popularity.
- **Comparison at the same level of abstraction:** comparing SOC 2 to CIS Controls to ISO 27001 requires putting them on the same axes (certifiable? unblocks what? time to first output?). Table format forces discipline.
- **Sequencing, not selection:** for most companies the answer is 'A first, then B, then C' rather than 'A instead of B'. The interesting question is order and cost of switching, not which one to pick.

- **What not to do:** naming the tempting-but-wrong paths (start with ISO, stack all three, skip CIS) is what makes recommendations trustworthy. It shows the author considered alternatives, not just defended a preference.
- **Timeline with milestones:** turns strategy into a plan. Anything without dates is a wish.